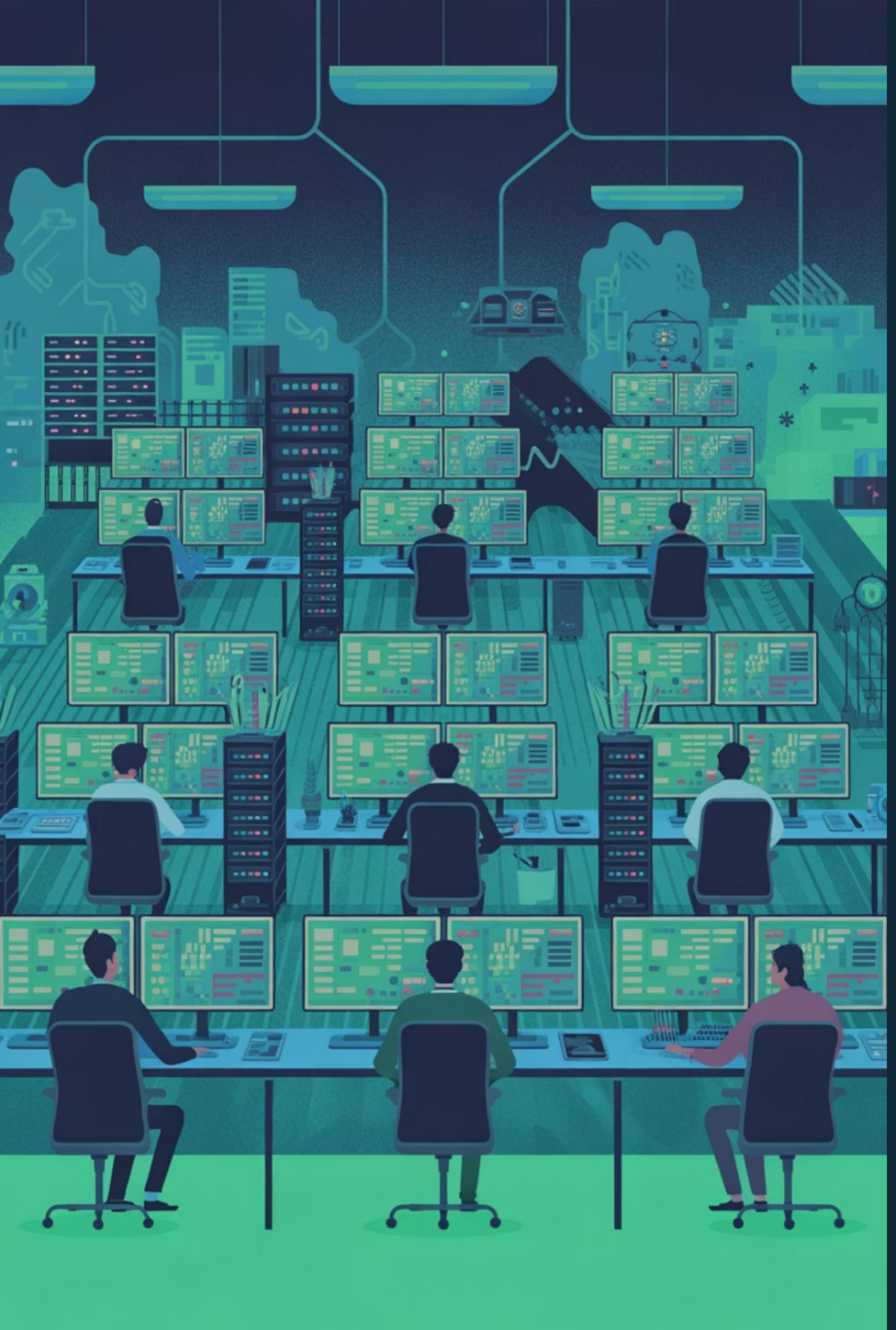


# AFS SOC: Vulnerability Management & Security Risk Analytics Report

**Aureon Financial Systems** · Security Operations Centre · March 2026

BY EMMANUEL ATEJI, SOC ANALYST

REF: AFS-SOC-VULN-2026-001

# Assessment Overview

A structured vulnerability assessment was conducted **20–26 February 2026** across two distinct targets, using an industry-standard toolchain across seven scan configurations.

## 2 Targets

Metasploitable 2 (internal Linux host) and testphp.vulnweb.com (web application)

## 5 Tools

Nessus · Qualys VMDR · OpenVAS · OWASP ZAP · Nikto

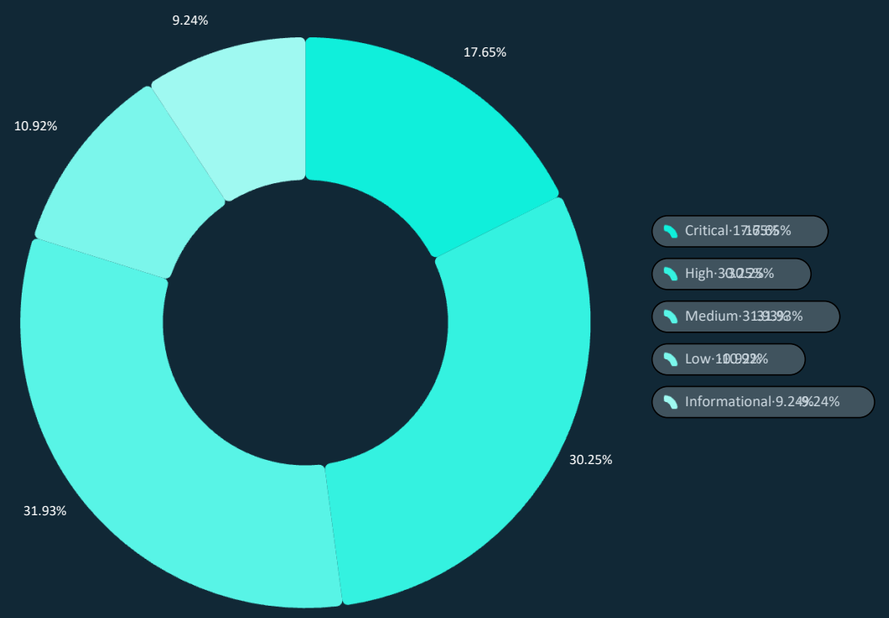
## 7 Scan Configs

Unauthenticated and credentialed scans across both targets

## 119 Vulnerabilities

Across all severity levels — from informational to critical

# Risk Distribution Across All Targets




## 119 Total Vulnerabilities Found

The distribution skews heavily toward the upper severity bands — **57 findings** (48%) are rated Critical or High, demanding immediate remediation action.

### 21 Critical

Immediate exploitation risk

### 36 High

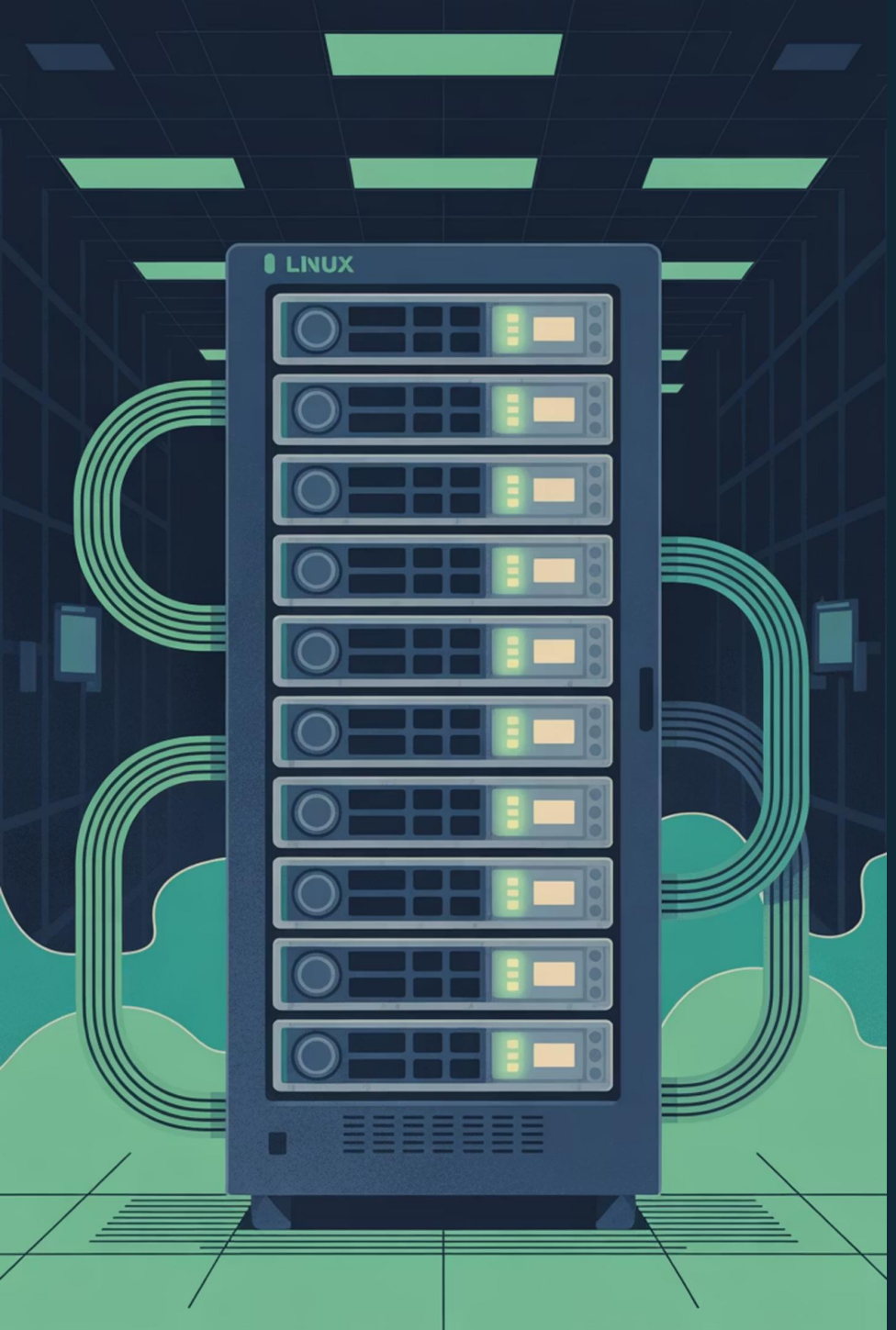
Significant exposure vectors

### 38 Medium

Require planned remediation

### 13 Low · 11 Info

Monitoring & hardening opportunities




TARGET 1

# Metasploitable 2 — Critically Compromised

Ubuntu 8.04 End-of-Life host. **101 vulnerabilities identified.** Rating: CRITICAL — ACTIVELY COMPROMISED

## EOL Operating System

Ubuntu 8.04 — unsupported since 2013. No security patches available.

## 4 Active Backdoors

Each grants instant root access with zero authentication required.

## 101 Vulnerabilities

Spanning kernel, services, credentials, and configuration weaknesses.

# Top Critical Findings — Target 1

### Ingreslock Backdoor

Bind shell listening on **port 1524** — instant root shell, no credentials needed.

2

### vsftpd 2.3.4 Backdoor

Trojanised FTP daemon opens a root shell on port 6200 when triggered.

3

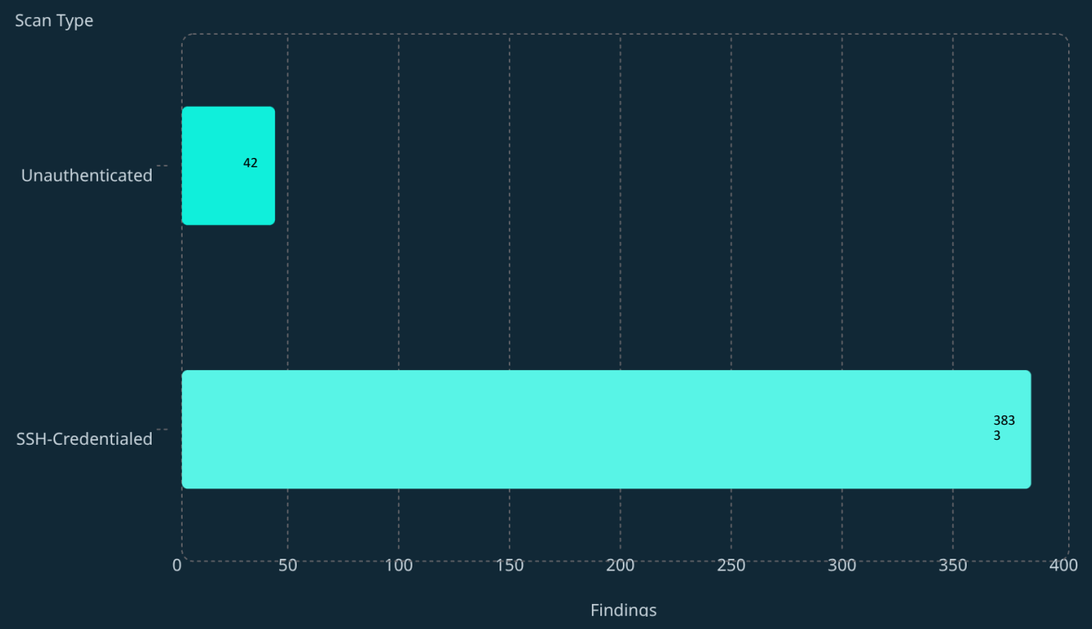
### UnrealIRCd RCE

**CVE-2010-2075** — Remote code execution via compromised IRC daemon.

### Shellshock + Ghostcat

**CVE-2014-6271** & **CVE-2020-1938** — Bash RCE and AJP file read. Default VNC/DB credentials also exposed.

# Key Insight: Credentialed vs Unauthenticated Scanning




## The Visibility Gap is Stark

Unauthenticated scans reveal only surface-level exposure. SSH-credentialed scans uncovered **383+ CVEs** — including kernel-level vulnerabilities, EOL package weaknesses, and deep configuration flaws invisible to external tools.

**Recommendation:** Credentialed scanning must be mandatory for all production servers. Unauthenticated scanning alone creates a dangerous false sense of security.

TARGET 2

# VulnWeb PHP Application — Immediately Exploitable

PHP 5.6.40 End-of-Life web application. **18 vulnerabilities identified.** Rating: CRITICAL — IMMEDIATELY VULNERABLE

### SQL Injection

Error-based and time-based blind injection across **6 endpoints**.

### No HTTPS

All credentials and session data transmitted in cleartext over HTTP.

### Stored XSS

Persistent cross-site scripting enabling session hijacking and phishing.

### PHP 5.6.40 EOL

End of life since **December 2018** — no security patches in 7+ years.

# Remediation Roadmap — Priority Actions

### P1 Isolate Host

Quarantine Metasploitable 2 within 24 hours

### P2 Remove Backdoors

Eliminate 4 backdoors and close ports within 24 hours

### P3 Upgrade PHP

Move to PHP 8.3 and enforce HTTPS within 24 hours

### P4 Parameterise SQL

Fix queries across 6 endpoints within 72 hours

### P5 OS Migration

Begin migration to Ubuntu 22.04/24.04 LTS within 72 hours

Prioritisation is based on exploitability and business impact. P1–P3 require emergency response within **24 hours**. P4–P5 must be scoped and initiated within **72 hours** to reduce regulatory exposure.

# Compliance Implications

Findings from this assessment map directly to multiple regulatory frameworks. The combination of cleartext transmission, unpatched EOL software, and unauthenticated database access creates **significant compliance liability** across financial and data protection obligations.

SQL injection + no HTTPS = likely **PCI-DSS violation**. Immediate remediation is required before any cardholder data processing occurs.

# Key Takeaways

## 1 EOL Software is the Root Cause

Upgrading to supported OS and runtime versions is the single highest-impact remediation action available.

## 2 Credentialed Scanning is Non-Negotiable

SSH-credentialed scans uncovered 9× more vulnerabilities than unauthenticated scans on the same host.

## 3 Both Targets Are Zero-Auth Exploitable

An attacker requires no credentials to achieve full system compromise on either target today.

## 4 Regulatory Exposure is Active, Not Theoretical

SQL injection over HTTP maps directly to PCI-DSS and GDPR obligations requiring immediate remediation.